

Kobayashi Maru — Document Pédagogique

Documentation complète de l'infrastructure — Profil E · MaisonVerte — Référence KM-M1-CDC-E — 2026

État du document (16/09/2026). Sections 1, 2, 3, 6 et 7a renseignées à partir de l'infrastructure réellement déployée et vérifiée (branche `work/integration-deploy`, 26 conteneurs sains sur `vulndb`, NAT OPNsense posé et testé depuis l'extérieur). Les sections 4 et 5 (preuves d'exploitation commande/sortie) restent à compléter après rejeu effectif des trois chaînes sur le terrain — la structure et les préconditions connues sont déjà en place. La section 7b (règles Suricata) reste à écrire. La section 8 (répartition nominative) reste à compléter par l'équipe.

1. Présentation de l'entreprise fictive et rappel du CDC choisi

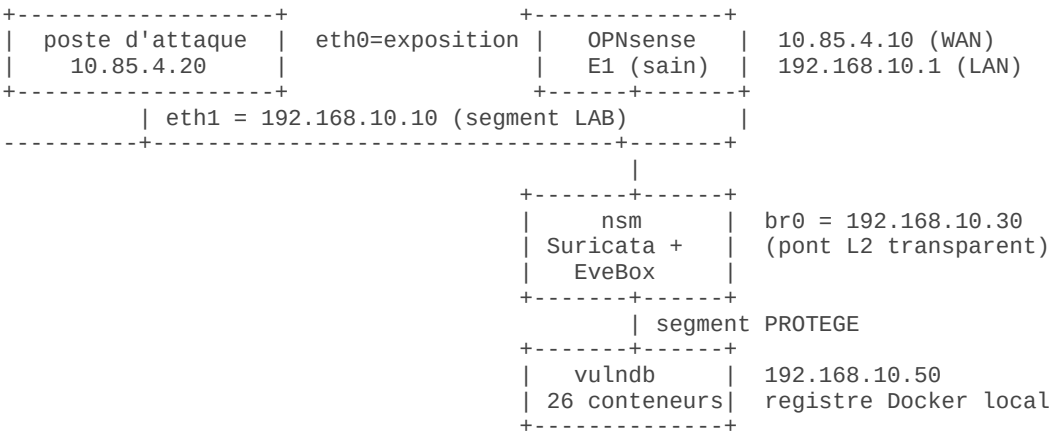
Champ	Valeur
Entreprise fictive	MaisonVerte SAS — enseigne de jardinerie et décoration d'intérieur
Secteur	Retail / e-commerce omnicanal (jardinerie, décoration)
Profil CDC choisi	Profil E — Reconstruction du SI omnicanal MaisonVerte (réf. KM-M1-CDC-E)
Domaine interne / public	Public : <code>maisonverte.fr</code> (shop, api, vendeurs, cache) via OPNsense <code>10.85.4.10</code> . Interne : zones DMZ / SRV / DATA / USERS / ADMIN / SHOPS sur <code>192.168.10.0/24</code> côté groupe, réseaux Docker <code>172.30.0.0/16</code> côté <code>vulndb</code> .
Zone spécifique	SHOPS — consolidation des ventes magasin et WMS entrepôt (12 points de vente, 1 entrepôt logistique de référence)
Actifs critiques	1) chiffre d'affaires en ligne (40 % du CA) ; 2) données personnelles clients et historique des commandes ; 3) continuité de l'encaissement en magasin

Résumé du CDC. MaisonVerte SAS (540 salariés, 12 points de vente en région, un entrepôt logistique, siège à Nantes) demande la reconstruction de bout en bout de son SI omnicanal — de la boutique en ligne jusqu'aux caisses de magasin — avant sa période commerciale de fin d'année. La boutique a été développée par une agence web externe (compte `agence.web` toujours actif), tandis que caisses et logistique sont gérées en interne ; les deux univers communiquent par traitements nocturnes et interfaces développées au fil de l'eau. Les magasins doivent pouvoir continuer à encaisser même si le lien vers le siège tombe. Périmètre inclus : services applicatifs, routeur périmétrique, segmentation, jeux de données de recette, supervision de sécurité, documentation. Périmètre exclu : terminaux de paiement bancaire réels (simulés), téléphonie, 11 des 12 magasins (un magasin de référence suffit).

2. Schéma réseau complet

Schéma détaillé disponible dans `suivi/schema-maisonverte.drawio`. Vue textuelle de la topologie physique et logique du lab (groupe G04) :

```
[autres groupes] --- segment EXPOSITION (10.85.4.0/24, un /24 par groupe, cloud-init)
```



Publication externe unique : 10.85.4.10:443 → NAT OPNsense → 192.168.10.50:443, où E2 (nginx) termine le TLS et distribue par SNI/Host vers E2, E3, E4, E5.

Zones du socle (réseaux Docker sur vulnldb)

Zone	Réseau Docker	Sous-réseau	Contenu
DMZ	net-dmz	172.30.10.0/24	E2, E3, E4, E5
SRV	net-srv	172.30.20.0/24	E6, E7, E8, E9, E14, E16
DATA	net-data	172.30.30.0/24	E10, E11
USERS	net-users	172.30.40.0/24	réservé (non utilisé par la tranche ferme actuelle)
ADMIN	net-admin	172.30.50.0/24	E15, ELK (Elasticsearch/Kibana/Filebeat défensifs)
SHOPS	net-spec	172.30.60.0/24	E12, E13

Micro-segments internes (un par maillon de chaîne, jamais publiés)

Chaîne	Micro-segments	Maillons couverts
A	mv-a-edge, mv-a-core, mv-a-data	E2–E7, E7–E8, E8–E10
B	mv-b-edge, mv-b-core, mv-b-data	E5–E14, E14–E12, E12–E11
C	mv-c-edge, mv-c-core, mv-c-spec	E3–E6, E6–E9, E9–E13

3. Tableau d'inventaire

État vérifié le 16/09/2026 sur vulnldb (docker ps) : 26 conteneurs actifs, tous healthy.

Nom du conteneur	Réseau Docker	Image	Version	Ports	Exposition
cache-dmz01 (E2)	net-dmz, mv-a-edge, mv-b-edge, mv-c-edge	vulhub/nginx	1	443	Publié — 192.168.10.50:443, seul point public
shop-dmz01 (E3)	net-dmz, mv-c-edge	vulhub/wordpress	4.6	80	Interne, via E2

shop-dmz01-db	backend privé E3	mysql	5	3306	Interne uniquement
mobile-dmz01 (E4)	net-dmz	vulhub/nginx	1	80	Interne, via E2 (sain)
market-dmz01 (E5)	net-dmz, mv-b-edge	build local (Dockerfile Tomcat)	8.5.19 (vulhub/tomcat base)	8080	Interne, via E2
backoffice-srv01 (E6)	net-srv, mv-c-core	vulhub/ofbiz	18.12.10	8443	Interne
search-srv01 (E7)	net-srv, mv-a-edge, mv-a-core	vulhub/elasticsearch	1.4.2	9200	Interne
cache-srv01 (E8)	net-srv, mv-a-core, mv-a-data	vulhub/redis	4.0.14	6379	Interne
files-srv01 (E9)	net-srv, mv-c-core, mv-c-spec	vulhub/samba	4.6.3	445	Interne
catalog-data01 (E10)	net-data, mv-a-data	vulhub/postgres	10.7	5432	Interne
clients-data01 (E11)	net-data, mv-b-data	vulhub/mongo-express	0.53.0	8081	Interne
clients-data01-mongo	backend privé E11	mongo	3.4	27017	Interne uniquement
pos-consol-shops01 (E12, executor)	net-spec, mv-b-core	vulhub/xxl-job	2.2.0-executor	9999	Interne
pos-consol-shops01-admin (E12, admin)	net-spec	vulhub/xxl-job	2.2.0-admin	8080	Interne
pos-consol-shops01-db	backend privé E12	mysql	5.7	3306	Interne uniquement
wms-shops01 (E13)	net-spec, mv-c-spec	vulhub/struts2	2.3.30	8080	Interne
deploy-srv01 (E14)	net-srv, mv-b-edge, mv-b-core	vulhub/jenkins	2.441	8080	Interne
supervision-admin01 (E15, web)	net-admin	zabbix/zabbix-web-nginx-mysql	alpine-7.0.27	8080	Interne (sain)
supervision-admin01-server	net-admin	zabbix/zabbix-server-mysql	alpine-7.0.27	10051	Interne (sain)
supervision-admin01-db	backend privé E15	mariadb	11.4	3306	Interne uniquement
crm-srv01 (E16)	net-srv	nginx	1.27.4-alpine	80	Interne (sain)
elk-admin01-es	net-admin	docker.elastic.co/elasticsearch/elasticsearch	7.17.24	9200	Interne uniquement (défensif, distinct de E7)
elk-admin01-kibana	net-admin	docker.elastic.co/kibana/kibana	7.17.24	5601	Publié en loopback vulndb uniquement (127.0.0.1:5601), tunnel

					SSH requis
elk-admin01-filebeat	net-admin	docker.elastic.co/beats/filebeat	7.17.24	—	Interne, lit les logs Docker en lecture seule
tp-registry	infra TP (hors tranche ferme)	registre Docker local	—	5000	Interne au lab, fourni par la plateforme
tp-registry-ui	infra TP (hors tranche ferme)	IHM du registre	—	5001	Interne au lab, fourni par la plateforme

4. Fiches des services vulnérables

Champs techniques (image, CVE, niveau, vecteur) confirmés depuis le build. Colonnes *exploit validé* / *preuve* / *preuve attendue* *attaquant* marquées à *renseigner* : les 3 chaînes n'ont pas encore été rejouées de bout en bout sur le terrain à la date de ce document.

Réf	Service	Image Vulhub	CVE / faille	Niveau	Vecteur d'attaque	Exploit validé	Preuve (sortie)	Emplacement
E2	Reverse proxy / cache	nginx/insecure-configuration	fuite d'info (alias mal configuré)	N1	Traversal / LFI via alias nginx, révèle la route de recherche interne	à renseigner	à renseigner	flag_id=1 (flag conteneur cache)
E3	Boutique WordPress	wordpress/pwnscriptum	RCE non authentifiée	N1	Exploit pwnscriptum, indice vers back-office E6	à renseigner	à renseigner	flag_id=2, contenu shop-dmz01
E5	Portail vendeurs Tomcat	tomcat/CVE-2017-12615	CVE-2017-12615	N1	PUT JSP non authentifié → webshell, indice Jenkins	à renseigner	à renseigner	flag_id=3, contenu market-dmz01
E7	Recherche produits	elasticsearch/CVE-2015-1427	CVE-2015-1427	N2	RCE Groovy non authentifiée, indice vers Redis	à renseigner	à renseigner	flag_id=4, contenu search-srv01
E8	Cache sessions	redis/4-unacc	accès non authentifié	N2	Redis sans mot de passe, lecture d'un secret PostgreSQL	à renseigner	à renseigner	flag_id=5, contenu cache-srv01
E10	Base catalogue / commandes	postgres/CVE-2019-9193	CVE-2019-9193 (COPY FROM PROGRAM)	N3	Exécution de commande via COPY FROM PROGRAM avec le compte de service	à renseigner	à renseigner	flag_id=6, contenu catalog-data
E14	Déploiement Jenkins	jenkins/CVE-2024-23897	CVE-2024-23897	N2	Lecture de fichier arbitraire via CLI non authentifiée, secret de job	à renseigner	à renseigner	flag_id=7, contenu deploy-srv01
E12	Consolidation ventes	xxl-job/unacc	executor sans authentification	N3	RPC executor 9999 non authentifié, exécution de commande	à renseigner	à renseigner	flag_id=8, contenu pos-consol-s
E11	Base clients	mongo-express/CVE-2019-10758	CVE-2019-10758	N3	Injection NoSQL → RCE via \$where, ou creds	à renseigner	à renseigner	flag_id=9, contenu clients-data

					par défaut admin/pass			
E6	Back-office commerçant	ofbiz/CVE-2023-51467	CVE-2023-51467	N2	Contournement d'authentification via ProgramExport, indice partage E9	à renseigner	à renseigner	flag_id=10, cont backoffice-s
E9	Fichiers marketing	samba/CVE-2017-7494	CVE-2017-7494 (is_known_pipename)	N2	RCE via partage accessible en écriture, procédure WMS trouvée	à renseigner	à renseigner	flag_id=11, cont files-srv01
E13	WMS entrepôt	struts2/s2-045	S2-045	N3	RCE via en-tête Content-Type (OGNL)	à renseigner	à renseigner	flag_id=12, cont wms-shops01

5. Chaînes de dépendance

Chaîne A — cache public → recherche → sessions → commandes

E2 → E7 → E8 → E10

Étape	Précondition	Information / accès obtenu	Mène à
E2	cache.maisonverte.fr publié via NAT	E2 Fuite d'info exposant la route de recherche interne	E7
E7	Accès via micro-segment mv-a-edge	Abus Elasticsearch, indice vers Redis	E8
E8	Indice E7 validé	Secret / credential PostgreSQL de service	E10
E10	Credential E8 validé	Flag catalogue/commandes	fin de chaîne

Preuves (commandes + sorties + alertes EveBox) à ajouter après rejeu terrain.

Chaîne B — portail vendeurs → CI/CD → batch → clients

E5 → E14 → E12 → E11

Étape	Précondition	Information / accès obtenu	Mène à
E5	vendeurs.maisonverte.fr publié via E2	Webshell JSP, indice Jenkins	E14
E14	Indice E5 validé	Lecture fichier / secret de job Jenkins	E12
E12	Secret E14 validé	Accès executor XXL-JOB, indice mongo-express	E11
E11	Credential E12 validé	Flag clients	fin de chaîne

Preuves (commandes + sorties + alertes EveBox) à ajouter après rejeu terrain.

Chaîne C — boutique → back-office → fichiers → entrepôt

E3 → E6 → E9 → E13

Étape	Précondition	Information / accès obtenu	Mène à
E3	shop.maisonverte.fr publié via E2	Exploitation WordPress, indice back-office	E6
E6	Indice E3 validé	Accès OFBiz, référence au partage Samba	E9
E9	Référence E6 validée	Procédure WMS / compte limité	E13
E13	Information E9 validée	Flag logistique	fin de chaîne

Preuves (commandes + sorties + alertes EveBox) à ajouter après rejeu terrain.

6. Comptes et accès

6a. Accès d'administration du lab (infrastructure)

Mots de passe volontairement omis de ce document versionné (rotés régulièrement par l'équipe) — voir le gestionnaire de secrets / canal privé de l'équipe pour les valeurs courantes.

Service	Compte	Mot de passe	Rôle / droits	Zone	Commentaire
OPNsense (webConfigurator)	root	— (canal privé équipe)	Administration complète du pare-feu du groupe	bordure (E1)	https://192.168.10.1/
Poste pivot / vulndb / nsm	etudiant	— (canal privé équipe, un mot de passe distinct par hôte)	Utilisateur standard, sudo autorisé	segment LAB	SSH 22, RDP 3389 sur le poste
Poste pivot / vulndb / nsm	root	— (canal privé équipe)	Superutilisateur	segment LAB	usage via sudo depuis etudiant de préférence

6b. Comptes applicatifs connus (par défaut Vulhub, intentionnellement faibles)

Service	Compte	Mot de passe	Rôle / droits	Zone	Commentaire
E3 WordPress — MySQL backend	root	root	Accès base shop-dmz01-db	DMZ (backend privé)	Défaut vulhub wordpress/pwnscriptum, non exposé hors conteneur
E10 PostgreSQL	postgres	postgres	Compte de service applicatif	DATA	Défaut vulhub postgres/CVE-2019-9193 ; la faille elle-même permet COPY FROM PROGRAM
E11 mongo-express (IHM)	admin	pass	Accès IHM mongo-express	DATA	Défaut vulhub ; l'exploit CVE-2019-10758 ne nécessite pas nécessairement ce login (injection NoSQL)
E12 XXL-JOB — MySQL backend	root	root	Accès base pos-consol-shops01-db	SHOPS (backend privé)	Défaut vulhub xxl-job/unacc
E12 XXL-JOB executor (9999)	—	—	Aucune authentification (c'est la vulnérabilité)	SHOPS	RPC non authentifié
E6 OFBiz	—	—	Contournement d'authentification	SRV	CVE-2023-51467, ProgramExport avec identifiants vides
E14 Jenkins	—	—	Lecture fichier arbitraire non	SRV	CVE-2024-23897 via CLI

authentifiée

E9 Samba	invité	—	Partage accessible	SRV	CVE-2017-7494, partage en écriture requis pour la RCE
E7 Elasticsearch	—	—	Aucune authentification (version 1.4.2)	SRV	CVE-2015-1427
E8 Redis	—	—	Aucune authentification	SRV	redis/4-unacc
E13 Struts2	—	—	RCE non authentifiée	SHOPS	S2-045, en-tête Content-Type
E2 nginx	—	—	Fuite d'info non authentifiée	DMZ	nginx/insecure-configuration

6c. Secrets générés au déploiement (pivots de chaîne)

Les identifiants de pivot découverts en cours de chaîne (ex. secret PostgreSQL révélé via Redis en chaîne A, token Jenkins révélé en chaîne B) sont générés à l'installation par `deployment/00-infra/prepare-runtime-secrets.sh` (`openssl rand -base64 24`) et stockés uniquement dans `deployment/state/secrets/` sur vulndb (permissions 600, répertoire exclu de Git). Ils ne sont jamais dupliqués dans le code, les fichiers Compose ni ce document ; leurs valeurs réelles seront relevées et masquées au moment du rejeu de chaîne (sections 4/5).

6d. Flags

Les 12 valeurs proviennent exclusivement de `enonce/flags-G04.csv` et sont mappées `service ↔ flag_id` dans `deployment/config/flags.map` (ordre : E2, E3, E5, E7, E8, E10, E14, E12, E11, E6, E9, E13). Les valeurs elles-mêmes ne sont pas reproduites dans ce document ; seul l'emplacement (conteneur / montage) est indiqué en section 4.

6e. Comptes métier attendus par le CDC (annexe client, à cartographier)

Compte	Rôle	Entité
f.leclerc	DSI	Informatique
n.roussel	Responsable e-commerce	Marketing
a.perrot	Acheteur, gestion du catalogue	Achats
resp.mag001 ... resp.mag012	Responsables de magasin, accès back-office	Magasins
logistique.entrepot	Gestionnaire d'entrepôt	Logistique
svc_deploy	Compte de service — déploiement	—
svc_caisse	Compte de service — remontée des ventes	—
agence.web	Compte agence ayant développé la boutique, toujours actif	Externe
client_test	Compte client de démonstration	Externe
vendeur_test	Compte vendeur de démonstration	Externe

Ces comptes sont ceux exigés par le CDC (annexe 11) ; leur implémentation concrète dans WordPress/back-office/portail vendeurs reste à documenter précisément lors du rejeu de chaîne.

7. Configuration OPNsense et règles Suricata

7a. Règles OPNsense (publication et filtrage)

Interfaces : WAN vtnet0 — 10.85.4.10/24, passerelle 10.85.4.1 ; LAN vtnet1 — 192.168.10.1/24.

#	Source	Destination	Port	Action	Motif métier
1	any (WAN)	wanip (10.85.4.10) → 192.168.10.50 (E2)	tcp/443	NAT port-forward, association filtre « pass »	Publication unique de la boutique/API/portail vendeurs/cache via le reverse-proxy E2 (SNI/Host)

Règle créée le 16/09/2026 (uuid 0c3808e8-de45-405e-8795-01e2396c1757) via le webConfigurator. Aucune règle Firewall > Rules > WAN distincte n'a été nécessaire : l'association « pass » de la règle NAT autorise directement le trafic correspondant. Vérifié fonctionnel depuis l'extérieur (VPN) le 16/09/2026 : shop.maisonverte.fr, api.maisonverte.fr, vendeurs.maisonverte.fr, cache.maisonverte.fr répondent tous en HTTP 200 sur 10.85.4.10:443. Aucune autre règle NAT/filter n'existe à ce jour (config <filter> vide par ailleurs) — cohérent avec le principe « rien n'est ouvert sauf ce qui est explicitement publié ».

7b. Règles Suricata

À écrire. Fichier cible : `/etc/suricata/rules/tp-local.rules` sur la sonde nsm (192.168.10.30), SID locaux à partir de 9000001. Familles à couvrir : reconnaissance, exploitation des 3 N1, mouvements latéraux, accès DATA/SHOPS, endpoints leurres, tokens AI-CANARY-*. Chaque règle devra être déclenchée au moins une fois et vérifiée dans EveBox (`http://192.168.10.30:5636/`) avant la recette finale.

8. Répartition des tâches nominatif

À compléter par l'équipe.

Membre	Service(s) alloué(s)	Vulnérabilité	Chapitre de documentation	Règle de détection
--------	----------------------	---------------	---------------------------	--------------------